

Статья Active Directory: от пассивной разведки до первого шелла – пособие для начинающих

 codeby.net/threads/active-directory-ot-passivnoi-razvedki-do-pervogo-shella-posobiye-dlya-nachinayushchikh.85943

July 4, 2025

[Добавить закладку](#)

Что такое Active Directory: архитектура, протоколы и ключевые компоненты

- служба каталогов Microsoft для Windows Server, представляющая собой иерархическую базу данных всех объектов корпоративной сети (пользователи, компьютеры, группы, политики). Для аутентификации использует Kerberos, для запросов к каталогу - LDAP, для разрешения имён - DNS.

Логическая структура AD, которую важно понимать до пентеста

- **Лес (Forest)** - высший контейнер безопасности; все домены внутри леса разделяют общую схему данных и глобальный каталог (Global Catalog).
- **Домен → Дерево** - независимые административные единицы со своими контроллерами домена (DC), политиками паролей и пулом SID. Деревья объединяют домены с общим DNS-пространством (например, `company.local` → `hr.company.local`).
- **Organizational Unit (OU)** - логический контейнер для делегирования прав и применения групповых политик (GPO). Не является границей безопасности.
- **Сайт (Site)** - физическое представление сети, управляющее репликацией между DC и маршрутизацией клиентских запросов к ближайшему контроллеру.

Службы, входящие в AD

Помимо (Domain Services), Active Directory включает: (Certificate Services) - PKI-инфраструктура, частый вектор атак (ESC1–ESC8); (Federation Services) - SSO и федеративная аутентификация; (Lightweight Directory Services) - LDAP-каталог без доменной привязки; (Rights Management Services) - защита документов.

Историческая справка

Первый релиз AD - Windows 2000 Server (1999). Начиная с Windows Server 2008 служба переименована в Active Directory Domain Services и расширена интеграцией с другими службами авторизации. До AD использовалась NT Directory Service (NTDS) - это имя до сих пор встречается в файлах (`ntds.dit`).

Углублённые материалы Codeby по теме:

- [Пентест Active Directory: полный гайд от разведки до Domain Admin](#)
- [Захват домена Active Directory: от учётки стажёра до Domain Admin мимо SOC](#)
- [Харденинг Active Directory глазами атакующего: Protected Users, Tiering Model и LAPS](#)



Содержание

- [Что такое Active Directory и почему это "Клондайк" для пентестера](#)
- [Определение своего положения: Вы в домене?](#)
- [Начало пассивной разведки: Сканирование и перечисление](#)
- [Глубокая разведка: Перечисление пользователей, групп и шар](#)
- [Получение первоначального доступа: Используем найденные учетные данные](#)
- [Что дальше? Следующие шаги в пентесте AD](#)
- [Риски для пентестера: О чём нужно помнить](#)
- [FAQ](#)

Привет, коллеги по цеху! Сегодня мы с вами откроем новую главу в нашем пентестерском блокноте. Помните, как в детстве мы искали клады на картах? Так вот, в мире кибербезопасности есть свой "Остров Сокровищ" – и это, без сомнений, . По статистике, подавляющее большинство (по оценкам, **более 90% организаций из списка Fortune 1000**) используют Active Directory для управления своими IT-

инфраструктурами, что делает его просто золотой жилой для пентестера. Наша цель — научиться его исследовать, как опытный археолог, не оставив ни следа. Важно помнить: все эти знания должны применяться **исключительно в рамках закона и с письменного разрешения владельца системы** (Rules of Engagement).

AD для чайников: ваш первый шаг в разведку домена

Что такое Active Directory и почему это "Клондайк" для пентестера

Итак, друзья, что же такое Active Directory (AD)? Если говорить простыми словами, это **централизованная служба каталогов (directory service)** от Microsoft, которая является **мозгом любой корпоративной сети** на базе Windows. Представьте себе огромную базу данных, которая хранит абсолютно всю информацию об инфраструктуре: от **пользователей и компьютеров** до **групп, сетевых ресурсов, настроек безопасности** и даже **хэшей паролей**. AD не только хранит эти данные, но и обеспечивает **аутентификацию** (проверку личности) и **авторизацию** (предоставление доступа к ресурсам) с использованием протоколов, таких как **Kerberos** и **NTLM**.

Для пентестера это не просто база, это настоящий "Клондайк", ведь тут можно найти всё, что нужно для компрометации домена, выполнения **латерального перемещения (Lateral Movement)** и получения контроля над всей сетью. Успешная компрометация AD часто означает получение **полного контроля** над большинством систем и данных в домене.

Логическая структура AD: Объекты, Домены, Деревья, Леса... и не только!

Чтобы понимать, куда копать, нужно знать, как это всё устроено. Active Directory имеет чёткую иерархию, которая организует все элементы для эффективного управления и администрирования. Давайте разберёмся в ней, двигаясь от самого высокого уровня к самым базовым кирпичикам:

1. Лес (Forest):

- **Самая верхняя и всеобъемлющая единица** в Active Directory. Представляет собой глобальную **границу безопасности**. Если вы скомпрометировали Лес, вы контролируете всю AD-инфраструктуру.
- Содержит одно или несколько **деревьев доменов (Domain Trees)**.
- Все домены в лесу автоматически связаны **двусторонними транзитивными доверительными отношениями**. Это означает, что пользователь из любого домена в лесу может (при наличии прав) получить доступ к ресурсам в любом другом домене леса.
- Имеет общую **схему (Schema)**, которая определяет все типы объектов (пользователей, компьютеров и т.д.) и их атрибуты, а также **конфигурационный раздел (Configuration Partition)** с информацией о топологии леса, сайтах и службах.
- Имеет один **корневой домен леса (Forest Root Domain)**, который создается первым и особенно важен для ролей **FSMO (Flexible Single Master Operations)** — уникальных ролей, которые отвечают за критически важные операции в лесу.

2. Дерево доменов (Domain Tree):

- Группа доменов, имеющих **непрерывное пространство DNS-имен**.
- Например: домен `contoso.com` является корневым деревом. Дочерний домен `europe.contoso.com` наследует пространство имен (`contoso.com`), а домен `asia.contoso.com` — тоже. Вместе они образуют единое дерево доменов.
- Все домены в дереве автоматически связаны **двусторонними транзитивными доверительными отношениями** благодаря принадлежности к одному лесу. Для пентестера это может создать неочевидные пути для **латерального перемещения** между, казалось бы, независимыми частями сети.

3. Домен (Domain):

- **Ключевая единица управления и репликации.** Именно внутри домена сосредоточена большая часть наших пентестерских изысканий.
- Представляет собой **границу политик безопасности (Security Boundary):** политики безопасности (например, парольная политика) применяются внутри домена.
- Представляет собой **границу репликации (Replication Boundary):** изменения объектов внутри домена реплицируются между всеми его **контроллерами домена (Domain Controllers, DC).**
- Содержит собственных пользователей, группы, компьютеры и другие объекты.
- Имеет уникальное **DNS-имя** (например, contoso.com, sales.contoso.com).
- Управляется одним или несколькими **контроллерами домена (DC)** – это сердце домена, сервер, который хранит реплику базы данных AD (**NTDS.DIT**, содержащую хэши паролей) и обрабатывает запросы аутентификации. Компрометация DC — это часто конечная цель для атак на Active Directory.

4. Подразделения (Organizational Units - OU):

- **Контейнеры внутри домена**, используемые для **логической организации объектов** (пользователей, групп, компьютеров, принтеров, других OU).
- Основной инструмент для **делегирования административных полномочий** и применения **Групповых политик (Group Policy Objects - GPO).** GPO, связанные с OU, применяются ко всем объектам в этой OU и её дочерних OU (если не настроено блокирование наследования или принудительное применение).
- Иерархия OU может быть глубокой (например, Домен -> OU=Отделы -> OU=Продажи -> OU=Менеджеры).
- **Важно: OU не являются границей безопасности сами по себе!** Права доступа определяются членством в группах безопасности, а не расположением в OU.

5. Контейнеры (Containers):

- **Стандартные папки**, создаваемые автоматически при создании домена (например, Builtin, Computers, Users).
- **Нельзя** напрямую применять к ним Групповые политики (GPO), что является их ключевым отличием от OU. Для управления объектами в стандартных контейнерах часто создают OU и перемещают объекты туда или используют специальные GPO, привязанные к домену и фильтруемые по группам безопасности.
- В отличие от OU, администраторы обычно **не могут создавать новые контейнеры** того же типа, что и встроенные.

6. Объекты (Objects):

- Конечные, самые мелкие элементы в иерархии AD, представляющие ресурсы сети.
- Примеры: Пользователь (User), Группа (Group), Компьютер (Computer), Принтер (PrintQueue), Общая папка (Shared Folder).
- Каждый объект имеет **уникальное имя** в рамках домена (**Distinguished Name - DN**) и набор **атрибутов** (например, имя пользователя, пароль, email, номер телефона). Каждый объект также имеет **уникальный GUID (Globally Unique Identifier)**, что полезно для автоматизированных инструментов.

Нам, как пентестерам, чаще всего предстоит работать в пределах одного домена и его OU, но важно помнить, что за ними могут скрываться целые леса, дающие доступ к ещё большим ресурсам.

Ключевые моменты, связанные с иерархией:

- **Глобальный каталог (Global Catalog - GC):** Это специальный контроллер домена, хранящий частичную репликацию *всех объектов во всем лесу*. Критически важен для поиска объектов по всему лесу и процесса входа в систему (особенно для универсальных групп).
- **Доверительные отношения (Trusts):** Обеспечивают механизм, по которому домены могут предоставлять доступ к своим ресурсам пользователям из других доменов. Внутри леса они автоматические и транзитивные. Можно создавать внешние, лесные, односторонние доверительные отношения с другими лесами или доменами Windows NT.
- **Сайты (Sites):** Представляют *физическую* топологию сети (на основе IP-подсетей) и управляют *репликацией трафика* между контроллерами домена, стараясь использовать каналы WAN как можно меньше. Важно понимать их для оптимизации репликации и планирования сетевого взаимодействия, хотя они и не являются частью *логической* иерархии объектов.

Схематично иерархия выглядит так:

Лес (Forest)

```
|
|— Дерево доменов 1 (Domain Tree 1)
|   |— Корневой домен дерева (e.g., contoso.com)
|   |   |— Подразделение (OU) 1 (e.g., Отделы)
|   |   |   |— Подразделение (OU) 1.1 (e.g., Продажи)
|   |   |   |   |— Объекты (Пользователи, Компьютеры, Группы...)
|   |   |   |   |— ...
|   |   |   |— Подразделение (OU) 1.2 (e.g., IT)
|   |   |   |— ...
|   |   |— Подразделение (OU) 2 (e.g., Офисы)
|   |   |— Контейнер (Container) (e.g., Computers, Users)
|   |   |— ...
```

```

|   └─ Дочерний домен (e.g., europe.contoso.com)
|       └─ Подразделения (OU)...
|           └─ ...
|
└─ Дерево доменов 2 (Domain Tree 2) [если пространство имен другое, e.g.,
fabrikam.com]
    └─ Корневой домен дерева (e.g., fabrikam.com)
        └─ ...

```

Понимание этой иерархии критически важно для эффективного проектирования, развертывания, управления и безопасности инфраструктуры Active Directory.

Определение своего положения: Вы в домене?

Прежде чем начать разведку, нужно понять одну простую, но очень важную вещь: вы вообще в домене? Этот вопрос звучит наивно, но ответ на него определяет весь дальнейший вектор ваших действий. Если вы уже на какой-то скомпрометированной машине, это первый чек-пойнт.

Как быстро проверить статус присоединения к домену через PowerShell

Самый удобный и информативный способ проверить доменное положение — это, конечно, PowerShell. Используем для этого объект `$ComputerSystem` или `Get-CimInstance`:

```

# Вариант 1: Через объект $ComputerSystem
$ComputerSystem | Select-Object Name, Domain, Workgroup, JoinStatus
# Вариант 2: Через Get-CimInstance (более детальный)
Get-CimInstance -ClassName Win32_ComputerSystem | Select-Object Name, Domain,
PartOfDomain, DomainRole

```

Разбираем вывод:

- **Name:** Имя вашего хоста.
- **Domain:** Имя домена, к которому присоединен компьютер. Если машина в рабочей группе, здесь будет пусто или имя рабочей группы.
- **Workgroup:** Имя рабочей группы (если машина не в домене).
- **JoinStatus:** Числовой статус присоединения. 1 означает "Workgroup", 2 — "Domain".
- **PartOfDomain:** True, если компьютер в домене, False — если в рабочей группе.
- **DomainRole:** Роль компьютера в домене (например, 0 для члена рабочей группы, 2 для контроллера домена).

Если Domain заполнен и JoinStatus равен 2 или PartOfDomain — True, поздравляю, вы в домене!

Альтернативный метод: Быстрая проверка через CMD

Если PowerShell недоступен (что бывает крайне редко на современных Windows), или вы просто хотите быстренько проверить, можно использовать старый добрый `cmd.exe`:

```
systeminfo | findstr /B /C:"Domain"
```

Эта команда выдаст строку, содержащую имя домена, если машина к нему присоединена. Если вы увидите что-то вроде `Domain: YourDomainName.local` — значит, цель найдена.

Начало пассивной разведки: Сканирование и перечисление

После того как мы убедились, что находимся в домене, самое время приступить к пассивной разведке. Почему пассивной? Потому что на этом этапе мы стараемся получить максимум информации, не производя агрессивных действий, которые могли бы вызвать тревогу у системного администратора или средств защиты. Это как пройтись вокруг дома, прежде чем стучать в дверь. Эта фаза соответствует тактикам **Reconnaissance (T1595)** и **Discovery (TA0007)** в **MITRE ATT&CK**, целью которых является сбор информации с минимальным шумом.

Целевое сканирование портов контроллера домена с Nmap

Первое, что мы сделаем, это просканируем контроллер домена (DC). В [разборе лабораторной задачи на HackerLab](#) можно увидеть, как эти методы применяются на практике. Нам не нужно сканировать все 65535 портов, это долго и шумно. Мы сосредоточимся на тех портах, которые критически важны для работы AD и, соответственно, интересны для нас. Наш верный спутник — **Nmap**:

```
sudo nmap -sV -sC -p 53,88,135,139,389,445,464,593,636,3268,3269,5985,5986,3389 <IP_DC>
```

Что означают эти флаги и порты?

- `-sV`: Определяет версии служб на открытых портах. Очень полезно для поиска уязвимостей.
- `-sC`: Запускает стандартные скрипты Nmap (например, `smb-enum-users`, `msrpc-enum`, `ldap-rootdse` и другие).

- -р . . . : Указываем конкретные порты для сканирования.
 - **53 (DNS)**: AD тесно интегрирован с DNS. Через него можно получить информацию о структуре домена.
 - **88 (Kerberos)**: Основной протокол аутентификации в AD. Здесь можно найти пользователей, попробовать брутфорс Kerberos (например, Kerberoasting или AS-REP Roasting).
 - **135 (MSRPC/EPMAP)**: Microsoft RPC Endpoint Mapper. Используется для связи с различными службами.
 - **139 (NetBIOS Session Service)**: Старый, но иногда полезный протокол для получения имен NetBIOS.
 - **389 (LDAP)**: Наша золотая жила! **Lightweight Directory Access Protocol**. Через него можно получить очень много информации об объектах AD, часто анонимно (**Null Bind**), если это не заблокировано.

*Важный нюанс: В современных, хорошо настроенных AD, Null Bind обычно отключен по умолчанию согласно лучшим практикам безопасности (например, от **NIST SP 800-63B**). Однако, его проверка всё равно имеет смысл в устаревших или плохо настроенных средах, так как обнаружение Null Bind говорит о существенных недоработках в безопасности домена.*
 - **445 (SMB/CIFS): Server Message Block**. Используется для обмена файлами, доступа к шарам и удаленного управления. Открывает возможности для перечисления пользователей, шар, а также выполнения кода **при наличии валидных учётных данных** (например, через PsExec) **или эксплуатации конкретных уязвимостей протокола** (как EternalBlue).
 - **464 (Kerberos Password Change/Set)**: Используется для смены паролей.
 - **593 (HTTP RPC EPMAP)**: Еще один порт для RPC.
 - **636 (LDAPS)**: Secure LDAP (LDAP по SSL/TLS).
 - **3268 (Global Catalog LDAP)**: **Глобальный каталог** – содержит частичную реплику всех объектов во всем лесу AD. Незаменим для поиска объектов по всему лесу.
 - **3269 (Global Catalog LDAPS)**: Secure Global Catalog LDAP.
 - **5985 (WinRM HTTP) / 5986 (WinRM HTTPS): Windows Remote Management**. Позволяет выполнять команды PowerShell удаленно. Наша будущая цель для пост-эксплуатации и латерального перемещения.
 - **3389 (RDP): Remote Desktop Protocol**. Удаленный рабочий стол. Еще одна цель для получения графического доступа.

Анализ открытых портов: Что ищем на контроллере домена

Каждый открытый порт – это потенциальная дверь. И вот что мы ищем, глядя на их список:

- **Порты 53, 88, 389, 445:** Их наличие на контроллере домена – абсолютная норма и необходимо для работы AD. Но это не значит, что они безопасны! Наоборот, они открывают путь для дальнейшей разведки и атак. Например, через **LDAP (389)** мы можем попробовать анонимно перечислить пользователей и группы. Если `smbclient -L \\<IP_DC> -N` показывает, что анонимный доступ к шарам разрешен на **SMB (445)** – это уже праздник! Также, уязвимости, такие как **ZeroLogon (CVE-2020-1472)**, демонстрируют, как даже "нормальные" порты могут быть критически опасны, если DC не обновлен.
- **Порты 5985 (WinRM) и 3389 (RDP):** Если они открыты, это отличные кандидаты для получения первоначального доступа и **латерального перемещения** после того, как мы найдем учетные данные.

Глубокая разведка: Перечисление пользователей, групп и шар

Теперь, когда у нас есть список открытых портов, пришло время нырять глубже. Мы будем использовать специализированные инструменты, которые автоматизируют сбор информации и помогут нам выудить самые "вкусные" данные. Эта фаза соответствует тактике **Discovery (TA0007)** в **MITRE ATT&CK**, включая техники **Account Discovery (T1087)**, **Group Policy Discovery (T1607)** и **Shared Drive Discovery (T1135)**.

Использование enum4linux-ng для детального перечисления информации

enum4linux-ng — это, по сути, продвинутая версия **enum4linux**, заточенная под современные реалии. Он может вытащить массу полезной информации, даже если у вас нет учетных данных. В отличие от своего предшественника, **enum4linux-ng** работает быстрее, поддерживает больше протоколов и скриптов, что делает его незаменимым для перечисления информации о Windows-системах и Active Directory.

```
enum4linux-ng -A <IP_DC>
```

Флаг **-A (all)** заставит его выполнить все доступные тесты: перечислить пользователей, группы, информацию о домене, парольные политики, шары SMB и многое другое.

Что мы увидим в выводе **enum4linux-ng**?

- **Пользователи:** Полный список логинов. Это золото для атак на пароли!
- **Группы:** Список групп и их членов. Помогает понять структуру привилегий.
- **Парольные политики:** Минимальная длина пароля, сложность, срок жизни. Это поможет нам в атаках методом перебора (brute-force) или использования словарей.

- **Шары SMB:** Список сетевых папок.

Все эти данные мы будем использовать для дальнейших шагов. Помимо `enum4linux-ng`, для более глубокой разведки в домене профессионалы используют такие инструменты как **BloodHound** ([подробный пример атаки через ACL и Graph Analysis](#)), **PowerView** (часть PowerSploit, мощные PowerShell-скрипты для разведки AD), и **ADRecon**.

Анонимный доступ к SMB: Поиск скрытых сокровищ

SMB – это не только для обмена файлами, но и для разведки. Иногда администраторы забывают закрыть анонимный доступ к стандартным шарам, таким как **NETLOGON** и **SYSVOL**. А там, друзья, порой можно найти настоящие сокровища! Согласно рекомендациям **NIST** (например, **SP 800-171**) и **CIS Benchmarks** для Windows Server, анонимный доступ к общим ресурсам должен быть строго ограничен. Проверить анонимный доступ можно так:

```
smbclient -L \\<IP_DC> -N
```

- `-L \\<IP_DC>`: Запрашиваем список шар на целевом хосте.
- `-N`: Означает "без пароля" (**null session**).

Если команда успешно покажет список шар, это уже половина победы. Особое внимание уделите шарам **NETLOGON** и **SYSVOL**.

Анализ содержимого SYSVOL и NETLOGON для поиска учетных данных

Почему именно SYSVOL и NETLOGON? Эти шары содержат **групповые политики (GPO)**, скрипты входа, файлы конфигурации – всё то, что распространяется на клиентские машины в домене. Современные исследования также подтверждают, что ошибки в конфигурации GPO могут существенно ослабить безопасность AD ([см. аналитический обзор в Electronics, 2022](#)). И вот тут кроется главная опасность: администраторы иногда по ошибке оставляют в этих файлах **захардкоженные (жестко прописанные) пароли или другую чувствительную информацию**. Это типичная ошибка конфигурации AD. Например, техника **Group Policy Preferences (GPP) (MITRE ATT&CK T1552.006)** описывает, как устаревшие GPP-файлы в SYSVOL могут содержать зашифрованные (но легко дешифруемые) пароли в `<cpassword>` тегах.

Чтобы посмотреть содержимое, можно использовать `smbclient` или просто подключить шару к своей системе:

```
smbclient \\\\<IP_DC>\\NETLOGON -N
ls
get <filename> # Например, get login_script.bat
```

Что искать?

- Файлы с расширениями **.xml**, **.ini**, **.ps1**, **.bat**, **.vbs**.
- В **.xml** файлах (особенно связанных с GPO, например, **Groups.xml**), ищите теги вроде **<crassword>** – это могут быть зашифрованные (но легко дешифруемые) пароли.
- В скриптах (**.bat**, **.ps1**, **.vbs**) ищите строки типа **password=** или **cred=**.

Получение первоначального доступа: Используем найденные учетные данные

Поздравляю, коллега! Если вы дошли до этого этапа, значит, вы нашли что-то ценное – скорее всего, учетные данные (логин/пароль или хэш). Теперь пришло время использовать их, чтобы получить доступ к системе и закрепиться. Этот шаг соответствует тактикам **Initial Access (TA0001)** (например, T1078 - Valid Accounts) и **Execution (TA0002)** (например, T1021.006 - Windows Remote Management) в **MITRE ATT&CK**.

Консольный доступ через WinRM с evil-winrm

WinRM (Windows Remote Management) – это протокол, который позволяет удаленно управлять Windows-машинами через PowerShell. Если порт **5985 (HTTP)** или **5986 (HTTPS)** открыт, а у вас есть учетные данные, **evil-winrm** станет вашим лучшим другом. Это мощный инструмент для получения интерактивной PowerShell-сессии, часто используемый для **латерального перемещения** и выполнения команд с привилегиями.

```
evil-winrm -i <IP_DC> -u <username> -p '<password>'
```

После выполнения этой команды, если учетные данные верны, вы получите PowerShell-сессию на контроллере домена! Отсюда можно выполнять любые команды PowerShell, загружать и выгружать файлы, запускать скрипты – полный контроль в рамках ваших привилегий.

Примеры команд внутри evil-winrm сессии:

```
whoami /all
```

```
Get-NetComputer -FullData | Select-Object Name, DNSHostName, OperatingSystem #
```

Список компьютеров в домене

```
ls # Просмотр файлов и папок
```

Графический интерфейс по RDP с xfreerdp

Иногда консоли недостаточно, и хочется увидеть графический интерфейс. Для этого на помощь приходит **RDP (Remote Desktop Protocol)**. Если порт **3389** открыт и у вас есть валидные учетные данные, вы можете подключиться к удаленному рабочему столу. На Linux для этого отлично подходит **xfreerdp**.

```
xfreerdp /v:<IP_DC> /d:<domain_name> /u:<username> /p:<password>
```

- /v:<IP_DC>: Целевой IP-адрес или имя хоста.
- /d:<domain_name>: Имя домена (не всегда обязательно, но полезно).
- /u:<username>: Имя пользователя.
- /p:<password>: Пароль пользователя. Если всё правильно, перед вами откроется рабочий стол контроллера домена или другой скомпрометированной машины. Это даст вам возможность визуально исследовать систему, запускать графические утилиты и выполнять другие действия, которые удобнее делать через GUI. Однако помните, что RDP может оставлять больше следов в логах, чем WinRM.

Что дальше? Следующие шаги в пентесте AD

После получения первоначального доступа и глубокой разведки, следующие этапы (см. [дорожную карту по инфраструктурному пентесту](#)) в рамках **kill chain** (например, по Lockheed Martin или MITRE ATT&CK) обычно включают:

1. **Повышение Привилегий (Privilege Escalation, MITRE ATT&CK TA0004):** Если мы получили доступ с правами обычного пользователя, наша следующая цель — получить более высокие привилегии на скомпрометированной машине или в домене. Это может включать эксплуатацию уязвимостей ядра, неправильных настроек файловых разрешений, или поиск учётных данных в памяти. Недавние работы по автоматизации анализа путей эскалации прав в AD показывают потенциал графовых моделей в обнаружении нетривиальных маршрутов ([см. preprint Arxiv, 2024](#)). Здесь особенно актуальны атаки на Kerberos, такие как:
 - **AS-REP Roasting:** Атака на пользователей, для которых **отключена пред-аутентификация Kerberos**. Это позволяет получить хэш их TGT-билета без предварительной аутентификации и брутфорсить его офлайн.
 - **Kerberoasting:** Атака, нацеленная на **Service Principal Names (SPN)**— [одна из ключевых техник, подробно разобранных в практической подборке атак на AD](#). Пентестер может запросить TGS-билеты для этих служб (которые зашифрованы хэшем пароля службы) и затем офлайн попытаться взломать их. Учётные записи служб часто имеют слабые или устаревшие пароли.
2. **Латеральное Перемещение (Lateral Movement, MITRE ATT&CK TA0008):** После получения привилегий на одной машине, мы стремимся переместиться на другие системы в домене, особенно на те, которые имеют более высокую ценность (например, файловые серверы, базы данных, другие контроллеры домена). Здесь активно используются техники **Pass-the-Hash**, **Pass-the-Ticket**, WMI, WinRM и RDP.
3. **Закрепление в Системе (Persistence, MITRE ATT&CK TA0003):** Чтобы не потерять доступ после перезагрузки или обнаружения, мы создаём механизмы для постоянного доступа к системе (например, создание новых учётных записей, установка бэкдоров, модификация системных служб).

4. **Обход Защиты (Defense Evasion, MITRE ATT&CK TA0005):** На каждом этапе пентестеру необходимо обходить средства защиты, такие как антивирусы, EDR-решения, файрволы. Это включает использование обфускации, легитимных системных утилит (**Living Off The Land - LOTL**) и методов, минимизирующих следы.
5. **Сбор Данных (Collection, MITRE ATT&CK TA0009) и Эксфильтрация (Exfiltration, MITRE ATT&CK TA0010):** Финальные стадии, где мы ищем и извлекаем конфиденциальные данные, являющиеся основной целью большинства атак. Одной из ключевых целей здесь является **дамп NTDS.DIT** с контроллера домена – файла, содержащего все хэши паролей пользователей. Для его извлечения требуются права Администратора домена или SYSTEM.

Риски для пентестера: О чём нужно помнить

Проведение пентеста, даже санкционированного, сопряжено с определёнными рисками, о которых важно знать:

- **Обнаружение:** Ваши действия, даже пассивные, могут быть обнаружены средствами защиты (SIEM, EDR, IDS/IPS), особенно если вы неаккуратны. Это может привести к блокировке вашего доступа, изоляции скомпрометированной машины и, в худшем случае, к расследованию инцидента.
 - **Блокировка/Чёрный список:** Сетевые устройства и системы безопасности могут автоматически блокировать ваш IP-адрес или учётные записи при обнаружении подозрительной активности (например, слишком много неудачных попыток входа, аномальные запросы).
 - **Юридические последствия:** Самый серьёзный риск. **Любые действия без явного, письменного разрешения** (Rules of Engagement), или выход за рамки этого разрешения, могут привести к серьёзным юридическим последствиям, включая уголовную ответственность. Всегда работайте в рамках контракта и этических норм.
 - **Ущерб системе:** Неосторожные действия могут случайно повредить систему, вызвать сбои в работе сервисов или потерю данных. Хотя пентестеры стремятся к минимальному воздействию, риски всегда есть.
- Поэтому **планирование, осторожность и глубокое понимание инструментов** крайне важны.

Заключение

Вот и подошла к концу наша первая вылазка в Active Directory, друзья. Мы с вами разобрали, почему AD — это лакомый кусочек для пентестера, научились определять своё местоположение в домене и освоили базовые, но крайне эффективные методы пассивной и активной разведки. Мы научились сканировать, перечислять пользователей и шары, а также получили первый, пусть и минимальный,

доступ к системе.

Помните, **разведка – это 80% успеха** любой атаки. Чем больше вы узнаете о цели на начальном этапе, тем точнее и эффективнее будут ваши дальнейшие действия. А главное – не забывайте про **этику и соблюдение законодательства**. Все эти знания мы применяем исключительно в рамках закона и с письменного разрешения владельца системы.

FAQ

- **Что такое контроллер домена (DC)?**

Сервер, который хранит базу данных Active Directory и управляет ею. Без него домен не работает.

- **Почему важно начинать с пассивной разведки?**

Чтобы минимизировать шум и риск обнаружения. Мы собираем информацию, не совершая агрессивных действий, что соответствует принципам скрытности в пентесте.

- **Что такое SYSVOL и NETLOGON?**

Это общие папки на контроллерах домена, используемые для распространения групповых политик и скриптов входа. Часто содержат ценную информацию из-за ошибок конфигурации.

- **Можно ли получить доступ к домену, не имея учетных данных?**

В редких случаях, при наличии серьезных уязвимостей (например, анонимный доступ к SMB-шарам, или критические уязвимости вроде ZeroLogon - CVE-2020-1472), это возможно. Но чаще всего разведка нацелена на получение учетных данных или хэшей для дальнейшего использования.

- **Чем enum4linux-ng лучше enum4linux?**

enum4linux-ng — это более современная и функциональная версия, которая лучше работает с новыми версиями Windows и имеет больше опций для детального перечисления, а также активнее поддерживается сообществом.

Практика – залог мастерства! Не откладывайте в долгий ящик, создайте [свою тестовую лабораторию](#) (например, используя VirtualBox/VMware и образ Windows Server) или воспользуйтесь платформами вроде **HackerLab** (категория **Pentest Machines**), TryHackMe или [курсом по пентесту AD от Академии Codeby](#), где подробно

рассматриваются аналогичные сценарии атаки. А если у вас есть свои фишки или вопросы – добро пожаловать в комментарии, обсудим!

Последнее редактирование: